

RECONNIASSANCE

Host discovery.txt

Starting Nmap 7.98 (<https://nmap.org>) at 2026-09-14 15:28 +0100

Nmap scan report for 192.168.78.1

Host is up (0.00032s latency).

MAC Address: 00:50:56:C0:00:01 (VMware)

Nmap scan report for 192.168.78.128

Host is up (0.00036s latency).

MAC Address: 00:0C:29:52:42:C7 (VMware)

Nmap scan report for 192.168.78.254

Host is up (0.00029s latency).

MAC Address: 00:50:56:F1:25:DF (VMware)

Nmap scan report for 192.168.78.129

Host is up.

Nmap done: 256 IP addresses (4 hosts up) scanned in 12.49 seconds

ENUMERATION

Contact-headers.txt

HTTP/1.1 200 OK

Date: Mon, 14 Sep 2026 14:45:00 GMT

Server: Apache/2.4.10 (Debian)

Content-Type: text/html; charset=UTF-8

Http header.txt

HTTP/1.1 200 OK

Date: Mon, 14 Sep 2026 14:36:07 GMT

Server: Apache/2.4.10 (Debian)

Last-Modified: Sun, 12 Aug 2018 22:29:32 GMT

ETag: "41b3-5734482bdcb00"

Accept-Ranges: bytes

Content-Length: 16819

Vary: Accept-Encoding

Content-Type: text/html

service-enumeration .txt

Starting Nmap 7.98 (<https://nmap.org>) at 2026-09-14 15:33 +0100

Nmap scan report for 192.168.78.128

Host is up (0.00020s latency).

Not shown: 997 closed tcp ports (reset)

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 6.7p1 Debian 5+deb8u4 (protocol 2.0)
80/tcp open http Apache httpd 2.4.10 ((Debian))
111/tcp open rpcbind 2-4 (RPC #100000)
MAC Address: 00:0C:29:52:42:C7 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
<https://nmap.org/submit/> .
Nmap done: 1 IP address (1 host up) scanned in 11.31 seconds

Wordpress-header.txt

HTTP/1.1 200 OK

Date: Mon, 14 Sep 2026 14:45:00 GMT

Server: Apache/2.4.10 (Debian)

Link: <<http://raven.local/wordpress/index.php/wp-json/>>; rel="https://api.w.org/"

Content-Type: text/html; charset=UTF-8

Analysis-note.txt

Finding 4:

The WordPress REST API exposes user information to an unauthenticated request.

Evidence:

GET /wordpress/index.php/wp-json/wp/v2/users

Response:

HTTP 200 OK

X-WP-Total: 1

User ID: 1

Username/display name: michael

Slug: michael

Assessment:

The endpoint exposes WordPress user metadata without requiring authentication. This can assist user enumeration and provides information that could be useful for further attacks. The test only confirmed information disclosure; no credential attack or account compromise was attempted.

Validation type:

Read-only, non-destructive API request.

Finding 5:

The WordPress REST API allows unauthenticated retrieval of published post metadata.

Evidence:

GET /wordpress/index.php/wp-json/wp/v2/posts

Response:

HTTP 200 OK

X-WP-Total: 1

Published post ID: 1

Author ID: 1

Assessment:

Published WordPress content is publicly accessible through the REST API. This is expected behavior for public posts and is documented as attack-surface information rather than a standalone vulnerability.

Validation type:

Read-only, non-destructive API request.

Finding 6:

WordPress uploads directory listing is enabled.

Evidence:

GET /wordpress/wp-content/uploads/

Response:

HTTP 200 OK

Directory listing displayed.

Exposed directory:

2018/

Assessment:

The WordPress uploads directory allows unauthenticated directory browsing. This exposes the directory structure and may reveal uploaded files that were not intended to be listed. The finding was validated using a read-only GET request.

Validation type:

Read-only, non-destructive request.

Finding 7:

WordPress uploads year directory listing is enabled.

Evidence:

GET /wordpress/wp-content/uploads/2018/

Response:

HTTP 200 OK

Directory listing displayed.

Exposed directory:

11/

Assessment:

The WordPress 2018 uploads directory allows unauthenticated directory browsing and exposes its subdirectory structure. This provides information about the location and organization of uploaded content.

Validation type:

Read-only, non-destructive GET request.

PHASE 4 – VULNERABILITY ANALYSIS

Finding 1:

WordPress version 4.8.7 was identified during enumeration.

Evidence:

The WordPress homepage HTML contains a generator tag identifying WordPress 4.8.7.

Current assessment:

The version is an outdated application version and should be investigated further for known security weaknesses. Version identification alone does not prove that the target is vulnerable.

Finding 2:

The WordPress REST API endpoint is exposed.

Evidence:

The HTML source identifies:

/wordpress/index.php/wp-json/

Current assessment:

The endpoint is accessible and should be assessed to determine what information it exposes. Accessibility alone does not prove a vulnerability.

Finding 3:

XML-RPC is exposed.

Evidence:

The HTML source identifies:

/wordpress/xmlrpc.php

Current assessment:

The endpoint is exposed and should be documented as part of the attack surface. No vulnerability conclusion has been made.

Next action:

Perform controlled, non-destructive validation of the identified web application exposure.

FINDING 8: WORDPRESS REST API MEDIA DISCLOSURE

Evidence:

The WordPress REST API media endpoint returned HTTP 200 and exposed one publicly accessible media record.

The response identified media ID 11, titled "flag3", with source URL:

/wordpress/wp-content/uploads/2018/11/flag3.png

The record also exposed the media author ID, filename, image dimensions, MIME type, and public source URL.

Assessment:

The REST API provides an additional unauthenticated path for discovering the uploaded flag3.png artifact. This confirms that application metadata and the location of the uploaded artifact are exposed through the WordPress REST API.

Validation type:

Read-only, non-destructive GET request.

Evidence file:

05_Initial_Access/wp-media-response.txt

Wp-components.txt

```
rel='stylesheet' id='twentyseventeen-style-css'
href='http://raven.local/wordpress/wp-content/themes/twentyseventeen/style.css?ver=4.8
.7' type='text/css' media='all' />
<link rel='stylesheet' id='twentyseventeen-ie8-css'
href='http://raven.local/wordpress/wp-content/themes/twentyseventeen/assets/css/ie8.cs
s?ver=1.0' type='text/css' media='all' />
<script type='text/javascript'
src='http://raven.local/wordpress/wp-content/themes/twentyseventeen/assets/js/html5.js?
ver=3.7.3'></script>
<meta name="generator" content="WordPress 4.8.7" />
<div id="wp-custom-header" class="wp-custom-header"></div> </div>
<script type='text/javascript'
src='http://raven.local/wordpress/wp-content/themes/twentyseventeen/assets/js/skip-link-
focus-fix.js?ver=1.0'></script>
<script type='text/javascript'
src='http://raven.local/wordpress/wp-content/themes/twentyseventeen/assets/js/global.js
?ver=1.0'></script>
<script type='text/javascript'
src='http://raven.local/wordpress/wp-content/themes/twentyseventeen/assets/js/jquery.sc
rollTo.js?ver=2.1.2'></script>
```

VULNERABILITY ANALYSIS

INITIAL ACCESS

Initial access-note.txt

Finding:

An uploaded image file is exposed through an unauthenticated WordPress uploads directory listing.

Evidence:

GET /wordpress/wp-content/uploads/2018/11/

Response:

HTTP 200 OK

Directory listing displayed.

Exposed file:

flag3.png

Size: 10K

Last modified: 2018-11-09 08:26

Assessment:

The directory listing exposes the name and location of an uploaded image file. This confirms that uploaded content can be discovered without authentication. At this stage, the finding is treated as information exposure and potential attack-surface discovery. No modification or destructive action was performed.

Validation type:

Read-only, non-destructive GET request.

File Access Validation:

Evidence:

GET /wordpress/wp-content/uploads/2018/11/flag3.png

Response:

HTTP 200 OK

Content-Type: image/png

Content-Length: 10411 bytes

Observation:

The previously exposed flag3.png file was directly retrievable without authentication. The server returned the image successfully, confirmed by the image/png content type and PNG file signature.

Assessment:

This confirms that an uploaded file identified through the publicly browsable uploads directory can also be accessed directly. The test was read-only and did not modify the target.

Validation type:

Read-only, non-destructive GET request.

WordPress Login Endpoint:

Evidence:

GET /wordpress/wp-login.php

Response:

HTTP 200 OK

WordPress login form displayed.

Observation:

The WordPress authentication endpoint is publicly accessible and presents username/email and password fields. No authentication attempt was made.

Assessment:

The login endpoint confirms an additional authentication surface on the target. Accessibility of the login page alone does not establish a vulnerability.

Validation type:

Read-only, non-destructive GET request.

OBJECTIVE ARTIFACT OBSERVATION

Evidence:

The publicly accessible file flag3.png was retrieved from the WordPress uploads directory.

Observation:

The image contains a lab-relevant write-up referring to flag3 followed by a hash-like value. The exact value has been preserved from the image without assuming its purpose or meaning.

Impact:

This demonstrates that an uploaded artifact containing potentially sensitive mission information can be discovered and retrieved without authentication.

Validation type:

Read-only, non-destructive GET request.

EVIDENCE INTEGRITY

The SHA-256 hash of flag3.png was calculated and saved separately as flag3.sha256 to preserve evidence integrity.

**Validation type:
Evidence integrity verification.**

LOGIN RESPONSE PRESERVATION

**The WordPress login page response was captured and saved as:
wp-login-response.txt**

The response confirms that the WordPress authentication interface is accessible over HTTP.

No credentials were submitted and no authentication attack was performed.

**Validation type:
Read-only evidence collection.**

ADDITIONAL WORDPRESS EXPOSURE

**Evidence:
The WordPress version was independently disclosed through wp-links-opml.php, which identifies WordPress 4.8.7.**

The WordPress readme.html file is also publicly accessible.

**Assessment:
These findings provide additional application fingerprinting information**

and confirm that WordPress installation-related files are publicly accessible. The generic installation documentation does not establish that default credentials are present on the target.

No authentication attempt or credential testing was performed.

**Validation type:
Read-only, non-destructive GET requests.**

Initial-access-conclusion.txt

PHASE 5 — INITIAL ACCESS CONCLUSION

Assessment status:

Initial authenticated access was not established.

Validated access finding:

The target's WordPress uploads directory was accessible without authentication. Directory listing exposed flag3.png, and the file was successfully retrieved using an unauthenticated HTTP GET request.

Evidence:

- /wordpress/wp-content/uploads/2018/11/
- /wordpress/wp-content/uploads/2018/11/flag3.png
- HTTP 200 OK
- Content-Type: image/png
- Content-Length: 10411 bytes

Security impact:

An unauthenticated user can discover and retrieve an uploaded artifact that contains lab-relevant information. This demonstrates unauthorized access to uploaded content, although it does not provide an operating-system shell or authenticated user session.

Evidence integrity:

The retrieved flag3.png file was preserved and its SHA-256 hash was calculated and stored separately.

Authentication testing:

No credentials were guessed or submitted. No password attack was performed.

Conclusion:

A successful unauthenticated access condition was demonstrated, but an authenticated host foothold was not obtained. Therefore, privilege escalation requiring a host session cannot be validly performed from the evidence collected in this phase.

RPC SERVICE VALIDATION

Evidence:

A read-only RPC enumeration was performed against TCP/111.

Result:

rpcbind was confirmed running with RPC status services registered on dynamically assigned ports.

Assessment:

The RPC service expands the target's attack surface, but the enumeration did not provide authentication credentials, an authenticated session, or evidence of successful host-level access.

Validation type:

Read-only service enumeration. No modification or exploitation was performed.

PRIVILEGE ESCALATION

Status.txt

STAGE 6 — PRIVILEGE ESCALATION STATUS

Status:

Not executed.

Reason:

No authenticated user session or shell-level foothold was established during the Initial Access phase.

Evidence from previous phases:

- SSH service identified on TCP/22.
- HTTP service identified on TCP/80.
- RPC service identified on TCP/111.
- WordPress application and version identified.
- Unauthenticated WordPress user information disclosure confirmed.
- Unauthenticated uploads directory listing confirmed.
- flag3.png successfully retrieved without authentication.
- Evidence integrity was preserved using SHA-256 hashing.

Assessment:

Privilege escalation requires an authenticated host-level session or equivalent initial foothold. Since no such foothold was established, performing privilege escalation would not be technically valid.

No credential guessing, authentication attacks, destructive actions, or unauthorized privilege-escalation attempts were performed.

Conclusion:

Stage 6 could not be executed because the required initial host foothold was not established.

Stage 6 could not be executed because the required initial host-level foothold was not established during Stage 5.

OBJECTIVE COLLECTION

Objective-collection.txt

STAGE 7 — OBJECTIVE COLLECTION

Objective artifact:

flag3.png

Location:

/wordpress/wp-content/uploads/2018/11/flag3.png

Collection method:

The artifact was identified through the publicly accessible WordPress uploads directory and retrieved using a read-only HTTP GET request.

Access status:

The file was accessible without authentication.

Evidence preserved:

- flag3.png
- flag3-value.txt
- flag3-http-response.txt
- flag3.sha256
- flag3-sha256.txt

Integrity:

A SHA-256 hash was calculated for the retrieved artifact and preserved in the evidence directory.

Assessment:

The objective artifact was successfully identified, retrieved, preserved, and verified. The collection was non-destructive and did not modify the target.

Additional note:

The artifact was obtained through unauthenticated application/file access.

No authenticated host-level foothold or privilege escalation was established.

Conclusion:

Stage 7 objective collection was successfully completed.

RESTORATION LOG

Restoration-log.txt

STAGE 7 — OBJECTIVE COLLECTION

Objective artifact:

flag3.png

Location:

/wordpress/wp-content/uploads/2018/11/flag3.png

Collection method:

The artifact was identified through the publicly accessible WordPress uploads directory and retrieved using a read-only HTTP GET request.

Access status:

The file was accessible without authentication.

Evidence preserved:

- flag3.png
- flag3-value.txt
- flag3-http-response.txt
- flag3.sha256
- flag3-sha256.txt

Integrity:

A SHA-256 hash was calculated for the retrieved artifact and preserved in the evidence directory.

Assessment:

The objective artifact was successfully identified, retrieved, preserved, and verified. The collection was non-destructive and did not modify the target.

Additional note:

The artifact was obtained through unauthenticated application/file access. No authenticated host-level foothold or privilege escalation was established.

Conclusion:

Stage 7 objective collection was successfully completed.

Operator-log.txt

PHASE 1 – RECONNAISSANCE

Target identified:

192.168.78.128

Discovery method:

Nmap host discovery

PHASE 2 – ATTACK-SURFACE ENUMERATION

Open TCP services identified:

22/tcp – SSH – OpenSSH 6.7p1

80/tcp – HTTP – Apache 2.4.10

111/tcp – RPCbind – 2-4

Operating system indication:

Linux/Debian

Next action:

Further enumerate the exposed services before forming a vulnerability hypothesis.
PHASE 0 – PREPARATION

Clean baseline snapshot created:

CIP-A105-CTF1-CLEAN-BASELINE

Target network:

Host-Only

Status:

Preparation completed. Ready for reconnaissance.

HTTP ENUMERATION

Target: 192.168.78.128

Port: 80/tcp

Server: Apache/2.4.10 (Debian)

HTTP Status: 200 OK

Page Title: Raven Security

Observed web paths:

about.html

service.html

team.html

wordpress

contact.php

Observation:

The target hosts a Raven Security website. A WordPress path is exposed and should be investigated as part of service enumeration.

WORDPRESS ENUMERATION

Target: 192.168.78.128

Path: /wordpress/

HTTP Status: 200 OK

Server: Apache/2.4.10 (Debian)

Observation:

WordPress is accessible on the target. The HTTP Link header exposes a WordPress REST API endpoint under /wordpress/index.php/wp-json/.

CONTACT PAGE ENUMERATION

Target: 192.168.78.128

Path: /contact.php

HTTP Status: 200 OK

Server: Apache/2.4.10 (Debian)

Observation:

The contact.php page is accessible and returns HTML content.

Next action:

Continue passive/service enumeration and identify additional application information before vulnerability analysis.

WORDPRESS APPLICATION ENUMERATION

Target: 192.168.78.128

Application: WordPress

Confirmed Version: WordPress 4.8.7

Theme: Twenty Seventeen

Observed endpoints/resources:

- WordPress REST API: /wordpress/index.php/wp-json/
- XML-RPC: /wordpress/xmlrpc.php
- RSS feed: /wordpress/index.php/feed/
- WordPress core directories: /wordpress/wp-content/ and /wordpress/wp-includes/

Observation:

The WordPress installation exposes application and version information through its HTML source. The WordPress version and several application endpoints were identified during passive enumeration.

Assessment status:

No vulnerability conclusion made at this stage. These observations will be considered during vulnerability analysis.

END OF ENUMERATION

The target's exposed network services and web application surface have been identified.

Confirmed services:

- 22/tcp – SSH – OpenSSH 6.7p1
- 80/tcp – HTTP – Apache 2.4.10
- 111/tcp – RPCbind

Web application findings:

- Raven Security website
- WordPress installation
- WordPress version 4.8.7
- Twenty Seventeen theme
- WordPress REST API endpoint
- XML-RPC endpoint
- contact.php

Next phase:

Vulnerability analysis based on the evidence collected during enumeration.

REST API USER ENUMERATION

Target: 192.168.78.128

Endpoint: /wordpress/index.php/wp-json/wp/v2/users

Method: GET

Authentication: None supplied

HTTP Status: 200 OK

Result:

The endpoint disclosed one WordPress user:

ID: 1

Name/slug: michael

Assessment:

Unauthenticated user metadata disclosure was confirmed. No login attempt, password guessing, or account modification was performed.

Evidence:

04_Vulnerability_Analysis/wp-users-response.txt

HASE 5 – INITIAL ACCESS

Vulnerability analysis completed.

Confirmed findings:

- WordPress 4.8.7 identified.
- WordPress REST API accessible without authentication.
- Unauthenticated WordPress user information disclosure conf>
- XML-RPC endpoint identified.
- Public post metadata accessible through the REST API.

Initial access will be attempted only after selecting a vali>

PHASE 6 – PRIVILEGE ESCALATION

Status:

Completed.

Objective:

flag3.png

The artifact was retrieved through unauthenticated access, preserved, and verified using SHA-256 hashing.

PHASE 8 – WITHDRAWAL AND RESTORATION

Status:

Completed.

The Raven target was restored to the clean baseline snapshot:

CIP-A105-CTF1-CLEAN-BASELINE

Final assessment status:

Evidence preserved and target restored to the clean laboratory baseline.